Encryption and Key Management Standard

Document ID	SEC-008
Department	IT and Information Security
Document type	Standard
Owner	Security Engineering Manager
Version	1.4
Status	APPROVED
Effective / last reviewed	2025-07-10
Audience	All employees and contractors
Related documents	SEC-005, SEC-009, ENG-014

Summary. Sets mandatory encryption algorithms, TLS versions, key lifecycle, KMS and HSM use, certificate management and secrets handling for Northstar Systems, with rotation periods, ownership, procedures, worked examples and exceptions.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This standard defines how Northstar Systems Private Limited protects data using cryptography and how cryptographic keys, certificates and secrets are generated, stored, rotated, backed up and destroyed. It exists so that Restricted and Confidential data stays unreadable to anyone who obtains storage media, network traffic or backups without authorisation, and so that key management is consistent across Engineering, IT Operations and Customer Success.

The standard applies to all employees and contractors, to every company-owned system and to every environment of the Northstar Nexus Platform, Nexus Connect and Nexus Insight, including production, staging and development, in the primary cloud region Mumbai and the secondary region Hyderabad. It covers data at rest, data in transit, keys, certificates, signing material and secrets. Data classes follow SEC-005. Backup encryption is detailed further in ENG-014, and network-layer controls are in SEC-009.

Any legal or regulatory references in this document are illustrative and must be verified by Legal before external use.

2. Definitions

- **KMS**: the cloud key management service provided by the cloud provider, used to create, store and control access to master and data encryption keys.
- **HSM**: hardware security module, a tamper-resistant device used to protect signing keys. Keys held in an HSM cannot be exported in plaintext.
- **Master key**: a key held in KMS that wraps other keys (also called a key encryption key or KEK).
- **Data encryption key (DEK)**: a key that encrypts actual data and is itself encrypted by a master key.
- **Signing key**: a private key used for code signing, signed Git tags, artifact signing in NorthShip, and token signing.

- **Secret**: any credential-like value such as an API token, database password, client secret or webhook signing secret.
- **NorthVault**: the password and secrets manager. A KMS-backed secret store may be used where an application needs secrets at runtime.
- **Key custodian**: the person or team named as responsible for a key, normally the service owner.
- **Cryptoperiod**: the time span during which a key may be used before it must be rotated.

3. Roles and Responsibilities

Role	Responsibility
Security Engineering Manager	Owns this standard, approves algorithms, reviews exceptions with the CISO delegate
CISO	Accepts residual risk and approves any exception to mandatory algorithms
Service owner (key custodian)	Registers keys, ensures rotation happens, removes keys when a service is retired
Platform Engineering	Operates KMS integration, certificate automation and the HSM
IT Operations	Operates NorthGuard disk encryption reporting and NorthVault
Security Operations	Monitors key usage and certificate expiry alerts in NorthWatch
Developers	Never place secrets in source code, use approved libraries only

4. Mandatory Algorithms and Protocols

Only approved, publicly reviewed algorithms may be used. Developers must not design their own cryptographic schemes.

Purpose	Requirement
Data at rest	AES-256
Data in transit	TLS 1.2 minimum, TLS 1.3 preferred
Password storage (application users)	Salted, adaptive hash such as Argon2id or bcrypt
Digital signatures	RSA 3072-bit or higher, or ECDSA P-256 or higher
Hashing for integrity	SHA-256 or stronger
Key exchange	Ephemeral Diffie-Hellman variants with forward secrecy

Prohibited: SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.1, DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, and any custom or home-grown cipher. Where a legacy customer integration still requires an old protocol, the exception process in section 12 applies.

5. Encryption at Rest

All Restricted and Confidential data must be encrypted at rest with AES-256. This includes production databases, object storage, file shares, message queues, search indexes, logs containing personal data, and backups. Encryption must be enabled when the resource is created; encrypting an existing unencrypted resource afterwards is treated as remediation and tracked in NorthDesk.

Endpoint rules: full-disk encryption is mandatory on every company laptop and is reported by NorthGuard. A laptop that is not reporting as encrypted is treated as non-compliant, is blocked from corporate resources through NorthID conditional access after 3 days and is escalated to the user's manager. Mobile devices enrolled for email and NorthID must have device encryption enabled by the operating system.

Database-level, volume-level and application-level encryption may be combined. Application-level (field) encryption is required for especially sensitive fields such as employee government identifiers, bank account numbers and customer secrets stored in Nexus Connect connector configurations.

Example: A Nexus Insight engineer needs a new analytics store for a Tier-2 service. The storage account is created through the standard infrastructure template, which turns on AES-256 encryption with a customer-managed KMS key. A manually created bucket without that setting would be flagged by weekly configuration scans and must be fixed within the vulnerability timeline for its severity.

6. Encryption in Transit

All network traffic that carries Internal data or higher must use TLS 1.2 or above, and TLS 1.3 is preferred for new services. This applies to public endpoints, internal service-to-service calls, database connections, replication to the secondary region Hyderabad, admin consoles, and traffic through NorthTunnel and NorthGate.

Rules:

1 Plain HTTP endpoints must redirect to HTTPS and must send an HSTS header on public sites.
2 Weak cipher suites must be disabled; only suites with forward secrecy are allowed.
3 Certificate validation must never be disabled in code, including in test code that can reach production.
4 Mutual TLS is required for service-to-service traffic of Tier-1 services that carries Restricted data.
5 Email to external parties containing Confidential data should use opportunistic or enforced TLS; Restricted data must not be emailed externally.

Customer-facing webhook deliveries from Nexus Webhooks must use HTTPS only. Customers configuring HTTP targets receive a validation error.

7. Key Management Lifecycle

7.1 Generation

Keys must be generated inside KMS or an HSM, or with a vetted cryptographic library that uses a secure random source. Keys must never be generated from passwords, timestamps or predictable values. Each key must have a single purpose; a signing key must not also be used for encryption.

7.2 Storage and access

Keys live in the cloud KMS. Signing keys live in an HSM. Master keys are never exported. Access follows least privilege and is granted through roles in NorthID, not to individual users. Humans do not have standing access to production DEKs. Any administrator action on a master key requires two authorised persons and is logged in NorthWatch.

7.3 Rotation

Key or secret	Rotation period
KMS master key	Every 12 months
Service account credentials	Every 90 days
TLS certificates	90-day lifetime with automatic renewal
Signing keys (HSM)	Every 24 months, or immediately after suspected exposure
Data encryption keys	Re-wrapped automatically when the master key rotates; re-encrypted with new DEKs every 24 months for Tier-1 data stores
API tokens issued to customers	Customer-managed; Nexus Workspace tokens should be rotated at least every 180 days

Rotation must be automatic wherever the platform supports it. Where it is manual, the key custodian receives a NorthDesk task 14 days before the due date. A missed rotation is a finding tracked to closure.

7.4 Backup and recovery of keys

Master keys in KMS are replicated within the provider's key service in the same region and, for Tier-1 services, a separate key in the secondary region Hyderabad is used to decrypt replicated data. Keys must not be copied to laptops, email or chat. Key backup material for the HSM is held in split custody by two named custodians in separate locations.

7.5 Revocation, compromise and destruction

A key suspected of compromise must be revoked and replaced immediately and the event reported to the Security Desk (ext. 5555 or security@northstar-systems.example) as a security incident under SEC-010. After revocation, data protected by the key must be re-encrypted with a new key, and an assessment must decide whether affected parties need notification.

When a key is retired, it must be disabled first and held in a disabled state for 30 days before scheduled deletion, so that backups and archived data can still be decrypted if something was missed. Destruction is recorded with the key identifier, date, approver and the systems that were checked. Where a key protects backups, it must be kept for as long as those backups are retained under ENG-014.

8. Certificates and TLS Management

TLS certificates have a 90-day lifetime and must renew automatically through the certificate automation service. Manual certificates are allowed only for systems that cannot automate, and need an owner, a calendar reminder and an expiry entry in the certificate inventory.

Certificate rules:

- Wildcard certificates are limited to the corporate domain and need Security Engineering approval; they must not be used for Tier-1 production services.
- Private keys for certificates must be generated on the system that will use them or in the HSM and must not be emailed.
- NorthWatch raises a warning 30 days, a high-severity alert 14 days and a paging alert 3 days before any certificate expires.
- Self-signed certificates may be used only in local development environments.

- All certificates issued must be recorded in the inventory with owner, service, expiry and issuing authority.

Example: The Nexus Connect API gateway certificate is due to renew, but the automatic renewal fails because of a DNS validation error. NorthWatch raises the 14-day alert. The Platform Engineering on-call engineer fixes the DNS record, renews manually and records the incident in NorthDesk. No customer impact occurs. Had the certificate expired, this would have been a SEV1 or SEV2 depending on scope.

9. Secrets Management

No secrets in source code, configuration files in repositories, tickets, chat messages, screenshots or wiki pages. Secrets must be kept in NorthVault or a KMS-backed secret store. NorthShip pipelines run secret scanning on every commit; a detected secret blocks the build. A secret found in a repository must be treated as compromised, rotated immediately and logged as a security event, even if the repository is private.

Rules for secrets:

1 Each application uses its own secrets; shared secrets across environments are prohibited. Production and non-production use different keys.
2 Applications fetch secrets at runtime using workload identities rather than long-lived static keys wherever possible.
3 Service account credentials are rotated every 90 days.
4 Privileged accounts use hardware security keys and 20-character passwords stored in NorthVault.
5 Developers needing a production secret for debugging must use just-in-time access (maximum 8 hours) through the access process in SEC-003, not copy it locally.

10. Cryptographic Libraries and Development

Developers must use maintained, approved libraries from the standard library or reputable vendors. Security-sensitive changes, including anything involving authentication, cryptography or PII handling, require review by a Security Champion in addition to the usual reviewers. Developers must not implement their own random number generators, padding schemes or protocols. Vulnerabilities in cryptographic libraries are remediated within the SLAs: Critical 72 hours, High 14 days, Medium 30 days, Low 90 days, and actively exploited issues are mitigated within 24 hours.

11. Monitoring and Audit

Security Operations reviews KMS and HSM audit logs weekly. The following events raise alerts in NorthWatch: key deletion scheduled, key policy changed, unusual decrypt volume, use of a key from an unrecognised role, failed HSM authentication, and certificate expiry. Security audit logs are retained 24 months in tamper-evident storage. The key inventory is reviewed quarterly by Security Engineering, and the external and internal audits check that rotation evidence exists.

12. Exceptions and Escalation

Exceptions to a mandatory algorithm, key location or rotation period must be requested in NorthDesk, with business justification, compensating controls and an end date. The Security Engineering Manager reviews and the CISO delegate must approve risk acceptance. The

maximum exception duration is 90 days; longer needs are re-approved. Typical examples include a customer system that cannot support TLS 1.2, which may be fronted by a gateway that terminates legacy traffic in an isolated network segment. Exceptions are recorded in the risk register.

Questions about this standard go to the Security Engineering team or the Security Desk. Suspected key exposure must be reported at once, never held until a convenient time.

13. Worked Scenarios

Scenario 1: Secret found in a repository

A developer in Engineering notices that a Nexus Connect staging client secret was committed to a feature branch two days ago. The NorthShip secret scan blocked the merge, but the commit remains in the branch history. The developer must tell the Security Desk the same day, rotate the secret in NorthVault, remove it from history with help from Security Engineering, and record the event in NorthDesk. Because the secret was only valid in staging and was never used from an unknown address, the Security Engineering Manager classifies it as Low severity. Had it been a production database password, the event would be handled as a security incident under SEC-010.

Scenario 2: Retiring a service

The Operations team retires an internal Tier-3 reporting tool. The service owner, as key custodian, lists the KMS keys and certificates used, disables the keys, and sets them to scheduled deletion after the 30-day hold. The owner confirms that the tool's backups are retained under ENG-014 for the required period, so the keys protecting those backups are kept until the last backup expires. The destruction record names the key identifiers, the approver and the check that no other service used the keys.

Scenario 3: Legacy customer needing TLS 1.1

A customer integration in a regulated sector cannot upgrade beyond TLS 1.1 for six weeks. Customer Success raises an exception request in NorthDesk. Security Engineering proposes an isolated gateway that terminates the legacy connection, forwards traffic internally over TLS 1.3 and logs every session. The CISO delegate accepts the risk for 90 days with a named owner and a migration plan. The exception is not extended unless a new risk acceptance is signed.

Scenario 4: Laptop not reporting encryption

NorthGuard shows that a laptop assigned to a Band B3 analyst has stopped reporting disk encryption status. IT Operations contacts the user the same day. If the agent cannot be repaired within 3 days, conditional access in NorthID blocks the device until the laptop is re-enrolled and shows as encrypted. The manager is informed but no disciplinary step is taken unless the user disabled encryption on purpose.

14. Frequently Asked Questions

- **May I encrypt a file with a password and email it?** Not if it holds Restricted data; Restricted data must not be shared by email externally. For Confidential data use the approved file-sharing tool with expiring links.
- **Can I store a test API key in a private repository?** No. Even test keys must be stored in NorthVault, because key-handling habits carry over to production.

- **Who decides when a key has to be rotated early?** The key custodian, with the Security Engineering Manager, after any suspected exposure.
- **Is TLS 1.2 still allowed?** Yes. It is the minimum. TLS 1.3 is preferred for new services.

15. Related Documents

See SEC-005 for data classification, SEC-009 (Network Security and VPN Standard) for network controls, ENG-014 for backup retention, SEC-003 for access management and SEC-010 for incident handling.

16. Revision History

Version	Date	Change
1.0	2024-03-18	Initial standard
1.3	2025-01-09	Added HSM split custody and 30-day disabled hold for retired keys
1.4	2025-07-10	Clarified certificate alert timing and secret scanning in NorthShip